Sample assessment — fictional company and vendor, written to show the method. Not a client deliverable.

Delivery gap assessment: AWS platform build

Field	Detail
Client	Acme Fieldwork, Inc. (fictional SaaS for field-service scheduling)
Vendor	[Vendor] (fictional, unnamed)
Contract	SOW "Production AWS platform", signed 2026-03-02; vendor reported completion 2026-09-30
AWS account	Example account (simulated), region us-east-1, production environment only
Evidence collected	2026-10-12 to 2026-10-14, read-only role (SecurityAudit + ReadOnlyAccess, data reads denied)
Reviewer	Tales Valcacer, AWS Certified Solutions Architect – Professional
Version	1.0, 2026-10-22 (after vendor right of reply)

1. Executive summary

The vendor's final status report (D-01) states that all ten SOW tasks are complete. The evidence supports a weighted completion between **55% (verified)** and **68% (supported)**. One task is complete and verified (audit logging); one is complete but not yet verified in production (CI/CD); seven are partial; one was not started (WAF).

- **The production database is single-AZ.** The SOW and the status report say Multi-AZ. The live instance (E-03) and the Terraform drift report (T-01) both show Multi-AZ off; drift shows it was changed outside Terraform.
- **Two IAM users have full administrator rights**, one with a long-lived access key and one console user without MFA (E-05). The SOW asked for no admin users and SSO sign-in.
- **The EKS API endpoint is open to the internet** (0.0.0.0/0) while the design document says private (E-02, D-02).
- **No web application firewall** is in place; the WAF code exists only on an unmerged branch (E-07, R-01).
- In good shape: network layout across three AZs, encrypted private database with deletion protection, AWS Backup plan, IRSA and OIDC roles for CI, CloudTrail with log file validation, and a working build, test and staging pipeline.

Recommendation: do not treat the platform as complete. Ask the vendor to close the gap items in section 6 under the current SOW, then re-check only those items.

2. Scope and method

In scope: the ten SOW tasks and their 30 acceptance criteria, as agreed with the client before evidence was collected. **Out of scope:** application code quality, load testing, cost optimisation, other accounts and regions.

Evidence levels (strongest first): L1 observed in the running system (AWS APIs, CloudTrail, CI run history) · L2 IaC state and plan · L3 repository and pipeline definitions · L4 documents · L5 claims. When sources disagree, the higher level wins and the item is marked *Contradicted*.

Scoring (full rubric in `method.md`): each criterion is Verified (L1), Supported (L2 to L4 only), Missing, Contradicted, or Unable to assess. Task *verified* % counts only Verified criteria; *supported* % adds Supported ones. Project completion is the SOW-weighted average, reported as a range. Statuses are the reviewer's judgments; the table below is computed from `scoring.csv` by `kit.py score`.

Limits: CloudTrail Event history covers 90 days (from 2026-07-15), so earlier events (such as the restore test, D-04) cannot be confirmed from the account. Billing console access was not granted.

3. Completion score

Task	Weight	Criteria V/S/M/C/U	Status	Verified	Supported
T1 Network	10	2/0/0/1/0	Partial	67%	67%
T2 EKS cluster	15	3/0/0/1/0	Partial	75%	75%
T3 PostgreSQL database	15	3/0/0/1/0	Partial	75%	75%
T4 Backups and restore	10	1/1/0/1/0	Partial	33%	67%

Task	Weight	Criteria V/S/M/C/U	Status	Verified	Supported
T5 IAM and access	15	2/0/1/1/0	Partial	50%	50%
T6 Audit logging	5	3/0/0/0/0	Complete, verified	100%	100%
T7 CI/CD	15	2/1/0/0/0	Complete, unverified	67%	100%
T8 Web application firewall	5	0/0/2/0/0	Not started	0%	0%
T9 Cost allocation tags	5	0/1/1/0/0	Partial	0%	50%
T10 Documentation and handover	5	0/1/0/1/0	Partial	0%	50%
Project (weighted)	100			**55%**	**68%**

Weights are the SOW line-item shares of the contract value.

4. Evidence by contracted item

SOW item and vendor claim	Evidence checked	Status	Gap
T1 VPC in 3 AZs, private workloads, NAT per AZ. *Claim: done.*	E-01 subnets, routes, NAT gateways; T-01; R-01 `infra/prod`	Partial	One NAT gateway (us-east-1a) serves all private subnets; IaC sets `single_nat_gateway = true`.
T2 EKS, supported version, private API, 3-AZ node group, audit logs. *Claim: done.*	E-02 cluster and node group; D-02 design doc	Partial	Public endpoint open to 0.0.0.0/0, private endpoint off. Contradicts D-02.
T3 PostgreSQL, private, Multi-AZ, encrypted, deletion protection. *Claim: done, Multi-AZ.*	E-03 instance; T-01 drift; D-01 status report	Partial	`MultiAZ = false`. Drift shows `multi_az` changed outside Terraform. No change request on file.
T4 Backups ≥14 days, AWS Backup daily/35 days, restore test. *Claim: done, tested.*	E-03 retention; E-04 plan; D-04 restore record; E-09	Partial	Retention 7 days. Restore record dated 2026-06-18, outside the event window: supported, not verified.
T5 No admin IAM users, IRSA, MFA, OIDC for CI. *Claim: least privilege done.*	E-05 users, policies, MFA, keys, roles; E-09 who used them	Partial	`vendor-deploy` (AdministratorAccess, active key) and `admin-temp` (admin via group, console, no MFA).
T6 Multi-region trail, validation, dedicated bucket. *Claim: done.*	E-06 trail and status	Complete, verified	None.
T7 PR build and test, auto deploy to staging, prod via pipeline with approval. *Claim: done.*	P-01 run history; R-01 workflow files; E-09 OIDC role use	Complete, unverified	Production job and approval gate exist in the workflow, but no production run has happened yet.
T8 WAF on public ALB with AWS managed rules. *Claim: done.*	E-07 web ACLs and ALB association; R-01 branches	Not started	No web ACL in the account. Draft code only on unmerged branch `feature/waf`.
T9 Required tags, cost allocation activated. *Claim: done.*	E-08 tags; D-03 screenshot	Partial	Database and ALB lack `cost-center`; log bucket untagged. Activation shown only in a screenshot.
T10 Architecture doc, deploy and restore runbooks. *Claim: delivered.*	D-02, D-04 against E-01, E-03	Partial	Architecture doc shows a Multi-AZ database and NAT per AZ, which do not exist.

5. Risks, ranked

#	Risk	Impact	Evidence	Fix effort
1	Admin IAM users with a long-lived key and a console login without MFA: one leaked credential gives full control of the account.	High	E-05, E-09	Low
2	Single-AZ production database: an AZ outage or maintenance event takes the product down, while documents say it is protected.	High	E-03, T-01, D-01	Low
3	EKS API open to the internet: cluster access depends only on credentials.	High	E-02	Low

#	Risk	Impact	Evidence	Fix effort
4	No WAF in front of the public application.	Medium	E-07	Medium
5	Backup retention 7 days instead of 14; restore not proven inside the record window.	Medium	E-03, D-04	Low
6	One NAT gateway: losing us-east-1a cuts outbound traffic for all private workloads.	Medium	E-01	Low
7	Architecture document does not match reality, which misleads future operators and auditors.	Low	D-02	Low
8	Tag gaps make cost reporting by team incomplete.	Low	E-08	Low

6. Recommendations

Before the platform is treated as complete (gap items, under the current SOW): remove both admin IAM users and the access key, and move remaining people to SSO (5.1, 5.3); enable Multi-AZ through Terraform, not the console (3.2); restrict or disable the public EKS endpoint (2.2); deploy and associate the WAF (8.1, 8.2); set backup retention to 14 days (4.1); add NAT gateways in us-east-1b and us-east-1c (1.3); correct the architecture document (10.1).

Evidence still needed from the vendor: a production pipeline run that passes the approval gate (7.3); a restore test inside the record window, with its CloudTrail events (4.3); billing tag activation shown by the client's own admin (9.2).

Re-check: after fixes, re-run the evidence kit and drift check for the changed items only, and issue a new version of this report. The completion range can inform the milestone decision; contractual consequences are for the client and its counsel.

Vendor right of reply (draft sent 2026-10-16, three business days): the vendor accepted 1.3, 4.1, 8.1 and 8.2. It disputed 3.2, stating Multi-AZ was turned off at the client's request to save cost. No written change request was found in D-01 to D-04, so the status stays *Contradicted* until the client confirms or rejects that request.

7. Evidence register

ID	Source	Level
E-00 to E-10	Evidence kit bundle, 2026-10-13, read-only role; SHA-256 of each file in `manifest.json`	L1
T-01	`terraform plan -refresh-only` and `terraform plan` on `infra/prod`, `-lock=false`, read-only role	L2
R-01	Platform repository: `main` branch and unmerged branches, 2026-03-02 to 2026-09-30	L3
P-01	CI run history exported by the client's admin	L1
D-01 to D-04	Vendor status report, architecture document v1.3, tagging handover note, runbooks with restore record	L4

8. Independence and sign-off

I have no commercial relationship with the vendor and no stake in the outcome. Remediation work is not part of this assessment. Evidence was collected with read-only access; nothing in the account was changed, and the reviewer role was removed on 2026-10-22.

Scripts collected facts through read-only API calls. I reviewed the evidence for every criterion and assigned every status myself; the scripts do not assign statuses.

	Name	Signature	Date
Reviewer	Tales Valcacer	*sample, not signed*	
Client acknowledgement	[Client representative]		